CLOUD AND IOT SECURITY

Security Issues and Attacks, Proposed Solutions, Tools and Techniques, and Future Research Directions at the Application and Service Layer of IoT Environment

Submitted to

Dr. Vijay Kumar Sharma

Submitted by

325103201 – Nithin
325103210 – Laahiri
325103217 – Banoth Jagan Naik
325403202 – Santoshi

M.Tech – Cyber Security

Department of Computer Science and Engineering

NIT Kurukshetra

Haryana, India

Contents

Abstract **iii**

1 Introduction **1**

1.1 Basic concepts 1

1.2 Objectives 2

1.3 Scope 3

2 Literature survey **4**

2.1 Security in the Internet of Things Application Layer: Requirements, Threats, and Solutions [3] 4

2.2 Exploring The Security Landscape: A Comprehensive Analysis OfVulnerabilities, Challenges, And Findings In Internet Of Things(Iot) Application Layer Protocols[1] 6

2.3 EBIDS: Efficient BERT-Based Intrusion Detection System in the Network and Application Layers of IoT [4] 8

2.4 Securing the IoT Application Layer From an MQTT Protocol Perspective: Challenges and Research Prospects [5] 9

2.5 A Survey on IoT Application Layer Protocols, Security Challenges, and the Role of Explainable AI in IoT (XAIoT) [2] 11

2.6 Securing and Sustaining IoT Edge-Computing Architectures Through Nanoservice Integration [6] 11

2.7 Securing IoT Using Lightweight TCN for Edge Deployment on Raspberry Pi 4 [7] 12

2.8 Safeguarding the IoT: Taxonomy, Security Solutions, and Future Research Opportunities [8] 13

3 Security Issues and Challenges in IoT Service and Application Layer **14**

3.1 Introduction 14

3.2 Overview of Security Challenges 14

3.3 Classification of Security Issues 15

3.4 Protocol Design Issues 15

3.5 Data Security Issues 15

3.6 Authentication and Authorization Issues 16

3.7 Application and API Vulnerabilities 16

3.8 Protocol-Specific Attacks 16
3.9 Intrusion Detection Challenges 17
3.10 Scalability and Resource Constraints 17
3.11 Interoperability and Standardization Issues 17
3.12 Attack Flow in IoT Application Layer 17
3.13 Summary 18

4 Proposed Solutions **19**
4.1 Introduction 19
4.2 Authentication and Access Control Solutions 19
4.3 Data Protection and Secure Communication 20
4.4 Protocol-Level Security Solutions 20
4.5 Application and API Security Solutions 20
4.6 Intrusion Detection and Monitoring 21
4.7 Edge-Based Security Solutions 21
4.8 Standardization and Secure Configuration 21

5 Conclusion and Future works **22**
5.1 Future Research Directions 22

Abstract

The rapid growth of the Internet of Things (IoT) has transformed various sectors such as healthcare, smart cities, agriculture, transportation, and industrial automation. IoT systems rely heavily on lightweight application layer protocols such as MQTT, CoAP, HTTP, AMQP, and DDS to enable communication between devices, services, and cloud platforms. However, due to resource constraints, scalability requirements, and lightweight protocol design, security is often not fully integrated at the application and service layers. As a result, these layers have become prime targets for cyberattacks including spoofing, replay attacks, denial-of-service attacks, unauthorized access, data tampering, and privacy breaches.

This report presents a comprehensive study of security issues and challenges in the IoT application and service layers. It categorizes security problems into protocol design weaknesses, data security issues, authentication and authorization flaws, API vulnerabilities, protocol-specific attacks, intrusion detection challenges, scalability concerns, and interoperability issues. A detailed literature survey is conducted to analyze existing research contributions, including machine learning-based intrusion detection systems, edge-based security solutions, and nano-service architectures.

The report further discusses practical countermeasures such as TLS/DTLS-based secure communication, role-based access control, token-based authentication, secure API management, intrusion detection systems, lightweight cryptographic techniques, and secure configuration practices. Special emphasis is given to edge computing security, explainable AI-based intrusion detection, and zero-trust architectures.

Finally, the report outlines future research directions including post-quantum cryptography for IoT, explainable machine learning models, protocol-aware security mechanisms, automated threat response systems, and global standardization efforts. The study concludes that a layered and integrated security approach is essential to ensure confidentiality, integrity, availability, and privacy in modern IoT application environments.

Introduction

1.1 Basic concepts

IoT refers to the network of interconnected devices capable of sensing and processing data while being able to communicate with other smart devices, while having limited computing power. The evolution of IoT devices has led to their adaptation in different sectors like education, communication, agriculture, and smart buildings. IoT devices are usually designed to be cheap, small, low power consumption, and always connected. To achieve this, manufacturers reduce CPU capability, memory, storage, and battery consumption. So, because of these low computational capabilities, they cannot implement complex encryption algorithms, frequent security updates, and proper authentication mechanisms, making them vulnerable points of the system.Not only are the number of security threats increasing but alos thier complexity due to the intorcution of intelligent systems .

1.1.1 General IoT Architecture or IoT Reference Model [1]

The general IoT architecture defines the structural organization of IoT systems and explains how devices, networks, and applications interact. Most reference models describe IoT using a layered approach to simplify design, deployment, and security analysis.

The commonly used IoT reference model consists of three main layers: the perception layer, the network layer, and the application layer. The perception layer includes sensors and actuators responsible for data collection from the physical environment. The network layer handles data transmission using wired or wireless communication technologies. The application layer processes data and provides services to end users.

Some extended architectures further divide IoT into five layers by adding transport and processing layers. These models improve scalability and help separate responsibilities between data communication, storage, and service management. The layered architecture also helps in identifying security issues specific to each layer.

From a security perspective, the application layer is more exposed to external threats because it interacts directly with users and cloud services. As a result, many recent studies focus on securing the application layer rather than lower layers.

—

1.1.2 IoT Application Layer Protocols [1][2]

IoT application layer protocols enable communication between IoT devices, servers, and applications. These protocols are designed to be lightweight and efficient to support devices with limited resources and unreliable network conditions.

Message Queuing Telemetry Transport (MQTT) is a widely used publish–subscribe protocol suitable for low-bandwidth and high-latency environments. Constrained Application Protocol (CoAP) follows a client–server model and is designed for constrained devices operating over UDP. Hypertext Transfer Protocol (HTTP) and HTTPS are also used in IoT systems that require web-based communication and integration with cloud platforms.

Other application layer protocols include MQTT-SN, Advanced Message Queuing Protocol (AMQP), Extensible Messaging and Presence Protocol (XMPP), and Data Distribution Service (DDS). Each protocol differs in terms of communication model, reliability, scalability, and security support.

Although these protocols provide flexibility and efficiency, several security challenges exist at the application layer. Common issues include weak authentication, lack of encryption by default, poor access control, and vulnerability to denial-of-service attacks. These limitations highlight the need for additional security mechanisms when deploying IoT application layer protocols.

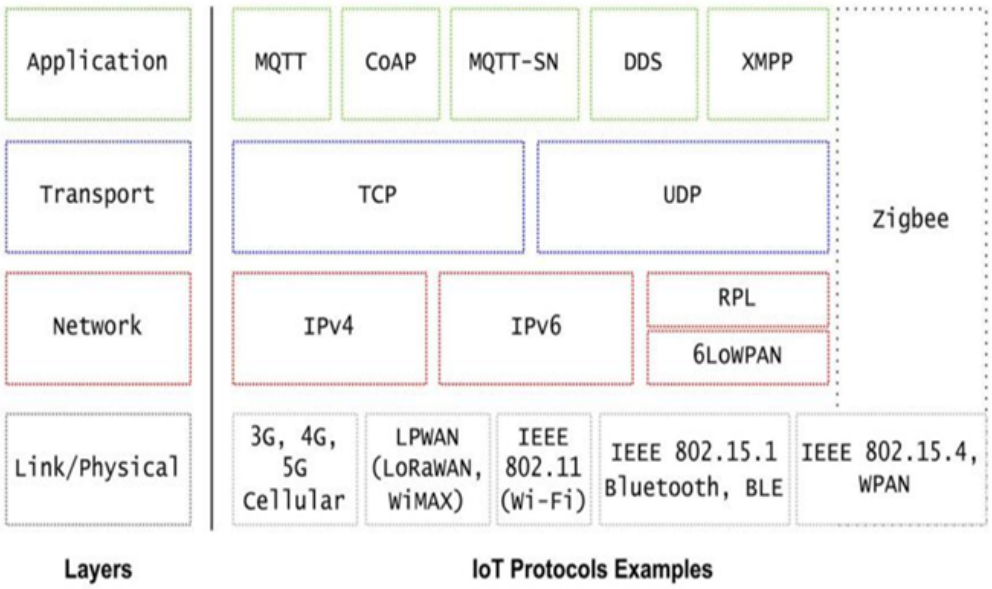

Figure 1.1: Common IoT application layer protocols [1]

1.2 Objectives

In this report, the main objectives are:

- To investigate the security issues and security requirements in the IoT application layer and categorize them.
- To discuss the attacks and threats targeting the IoT application layer.
- To list and analyze existing security countermeasures proposed in the literature.

- To survey the existing tools used for securing the IoT application layer.
- To discuss open challenges and identify future research directions.

1.3 Scope

- Limited to the security of the IoT application layer only.
- The study focuses on commonly used IoT protocols only.
- The report does not include implementation and experimental evaluation.

Literature survey

2.1 Security in the Internet of Things Application Layer: Requirements, Threats, and Solutions [3]

Overview

The paper [3] presents a structured survey of IoT application layer security and discusses the major security requirements, threats, and existing solutions. Additionally, the paper highlights open issues and future research directions.

2.1.1 Security requirements of IoT Application Layer

- Confidentiality
- Integrity
- Availability
- Authentication and authorization
- Non-repudiation
- Privacy

2.1.2 Security threats and solutions in the IoT Application Layer

Table 2.1: Security Analysis of IoT Application Layer Based on Use Cases [3]

IoT Use Case	Security Requirements	Major Threats	Proposed Solutions
Smart Grids	Confidentiality Integrity Availability Privacy	Eavesdropping Spoofing False data injection DoS Man-in-the-middle	Encryption Authentication mechanisms Secure gateways Anomaly detection Anti-jamming techniques
Smart Healthcare	Confidentiality Integrity Authentication Authorization Privacy Non-repudiation	Unauthorized access Eavesdropping Data tampering Replay attacks Privacy leakage	AES/SHA encryption Digital signatures Access control mechanisms Data freshness verification
Intelligent Transportation Systems (ITS)	Confidentiality Integrity Availability Authentication Non-repudiation	Spoofing Sybil attacks Man-in-the-middle DoS Jamming Adversarial ML attacks	Cryptographic techniques Message authentication codes (MACs) Digital signatures Challenge-response protocols
Smart Agriculture	Privacy Authentication Confidentiality Integrity Availability	Eavesdropping Impersonation False data injection DoS Jamming	Privacy-preserving aggregation Access control Authentication mechanisms Blockchain-based solutions
Industrial IoT (IIoT)	Authentication Confidentiality Integrity Availability	False data injection Spoofing Malware Man-in-the-middle DDoS	Trust-based authentication Public Key Infrastructure (PKI) Cryptographic techniques SDN-based monitoring
Smart Cities	Confidentiality Integrity Availability Privacy	DoS attacks Malware Eavesdropping Masquerade attacks Disinformation attacks	Blockchain solutions Cryptographic techniques Access control mechanisms Machine learning-based detection Data anonymization

Table 2.2: Security Threats and Solutions of IoT Application Layer Protocols [3]

Protocol	Threats	Solutions
MQTT	Authentication issues Authorization issues Message delivery failures Message integrity issues	Client/device authentication Authorization of client access to servers Message privacy-preserving mechanisms Message integrity checking mechanisms
CoAP	IP spoofing Caching and proxying vulnerabilities Block attacks Parsing attacks	Adopting DTLS security modes Access control mechanisms Secure communication Confirmable messages
XMPP	Unauthorized access Stanza modification Stanza deletion/replaying	Protocol improvement SASL authentication
mDNS	DoS attacks Poisoning attacks Remote attacks	Limitation on mDNS services Closing port
SSDP	Reflection/amplification attacks Passive attacks Eavesdropping attacks Poisoning attacks	Limitation on SSDP services Message monitoring and blocking Encryption techniques

2.1.3 Future research directions

- Lack of comprehensive security or provacy protection frameworks
- insecure interfaces
- scalability related security challenges
- Integrating blockchain, Machine learning or network virtualization with IoT

2.2 Exploring The Security Landscape: A Comprehensive Analysis OfVulnerabilities, Challenges, And Findings In Internet Of Things(Iot) Application Layer Protocols[1]

2.2.1 Overview

The paper by Sushil Kumar Bhoi[1] discusses the following aspects

- The diversity in devices , the protocols used by them and also how they communicate with each other
- Emphasis on the lack of universal standards for authentication

- The paper mainly focusses on MQTT, CoAP, AMQP,XMPP and DDS protocols

The paper proposed application layer can be secured through mechnisms like authentication, encryption, Access control lists(ACL) Anti malware softwares, Continuous risk assesment and intrusion detections The security issued identifies by the paper include :

Table 2.3: Security Issues in IoT Application Layer Protocols (Part I)

Protocol	**Security Mechanisms**	**Key Security Issues and Limitations**
MQTT	Client ID authentication, Username/Password, ACLs, TLS/SSL	• Security mechanisms are disabled by default • Authentication relies on client ID and credentials • TLS is resource-intensive for constrained devices • End-to-end encryption increases overhead • SMQTT with ABE offers fine-grained access control • High overhead with many subscribers
CoAP	DTLS, Pre-shared keys, Raw public keys, Certificates	• Key management complexity • DTLS handshake causes fragmentation and latency • High overhead for constrained devices • Certificate-based authentication increases cost

AMQP	TLS over TCP	• Vulnerable to replay and masquerade attacks • Message modification and DoS attacks • Botnet attacks exploit weak authentication • Malware propagation in enterprise IoT systems
DDS	TLS, DDS Security Standard	• Initially relied only on TLS • Vulnerable to unauthorized publishers/subscribers • Limited experimental validation of DDS Security • Critical risks in industrial and military systems

2.3 EBIDS: Efficient BERT-Based Intrusion Detection System in the Network and Application Layers of IoT [4]

The EBIDS study presents a BERT-based intrusion detection system designed to secure IoT network and application layers. The primary objective of EBIDS is to automatically detect malicious activities by learning patterns from IoT traffic data. The approach focuses on distinguishing normal application-layer behavior from attack traffic.

The methodology begins with the collection of application-layer IoT data from devices and services. Since raw data often contains noise and features with different scales, preprocessing techniques are applied. These include feature selection, dimensionality reduction using Principal Component Analysis (PCA), and data normalization. These steps improve data consistency and learning efficiency.

After preprocessing, the data is converted into a format suitable for BERT. Tokenization is performed using the WordPiece method, and special tokens such as [CLS] and [SEP] are added. The tokenized inputs are transformed into embeddings, including token embeddings, positional embeddings, and segment embeddings.

The embedded sequences are processed through multiple BERT transformer layers. The self-attention mechanism captures contextual relationships between application-layer features. The output corresponding to the [CLS] token is then passed to a fully connected classification layer, which labels traffic as either normal or malicious. The EBIDS model demonstrates effective detection of complex and previously unseen application-layer attacks.

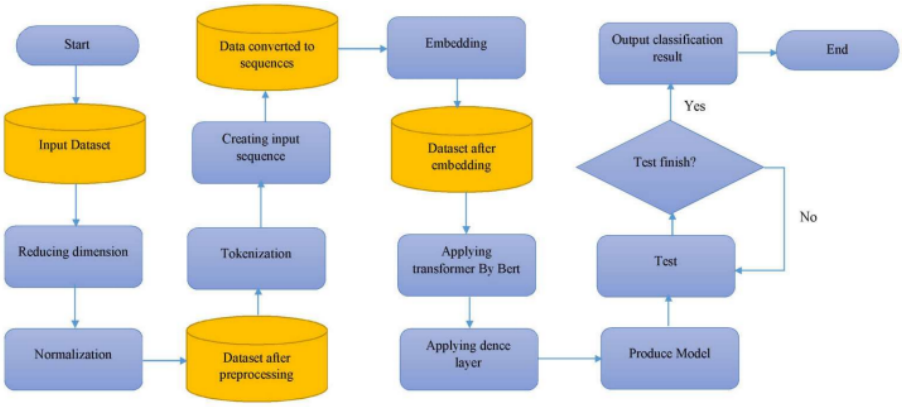

Figure 2.1: Flowchart of the EBIDS Model [4]

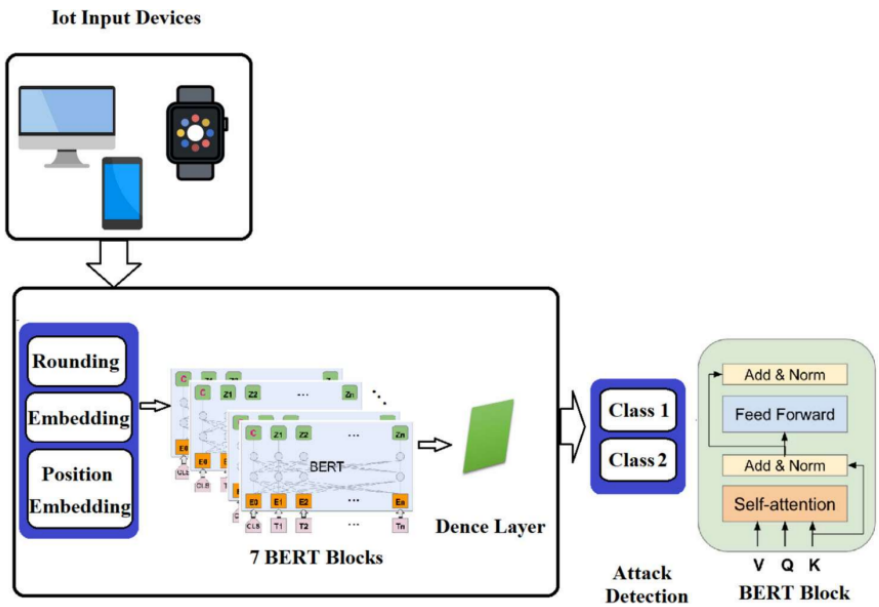

Figure 2.2: Proposed BERT Architecture for IoT Intrusion Detection [4]

2.4 Securing the IoT Application Layer From an MQTT Protocol Perspective: Challenges and Research Prospects [5]

The referenced study examines security challenges in the IoT application layer with a focus on the MQTT protocol. MQTT is widely adopted due to its lightweight design, low power consumption, scalability, and reliable message delivery. However, these characteristics also increase exposure to security threats.

The analysis identifies MQTT vulnerabilities and classifies them into two major categories. The first category includes protocol design limitations, such as the lack of built-in authorization mechanisms and the absence of payload encryption. These weaknesses enable attackers to intercept messages, manipulate topics, or perform denial-of-service attacks.

The second category includes implementation-related vulnerabilities. These vulnerabilities result from insecure configurations, including the absence of SSL/TLS usage, weak authentication mechanisms, insufficient message validation, and non-compliance with MQTT standards. Such issues further expand the attack surface of MQTT-based systems.

The study also categorizes common attacks targeting MQTT, including replay attacks, man-in-the-middle attacks, identity spoofing, information disclosure attacks, and denial-of-service attacks. By mapping attacks to vulnerabilities, the analysis provides a detailed understanding of malicious activities at the IoT application layer.

The paper further discusses security mechanisms such as secure configuration practices, encryption through SSL/TLS, authentication techniques, intrusion detection systems, and anomaly detection approaches. Lessons learned, research challenges, and future research directions are also presented.

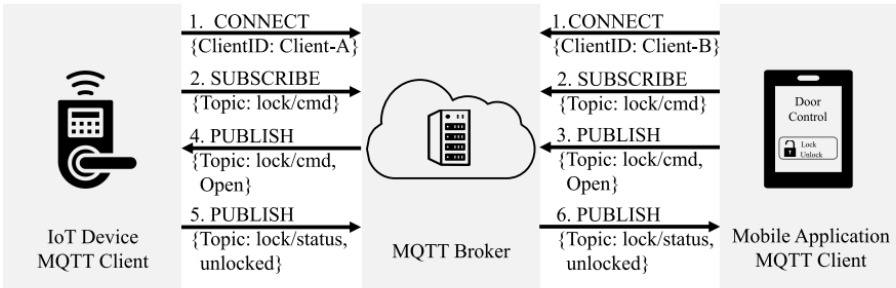

Figure 2.3: Structural Framework of the MQTT Messaging Model [5]

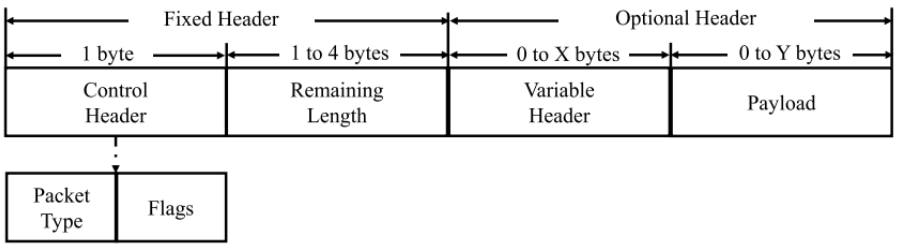

Figure 2.4: MQTT Packet Format [5]

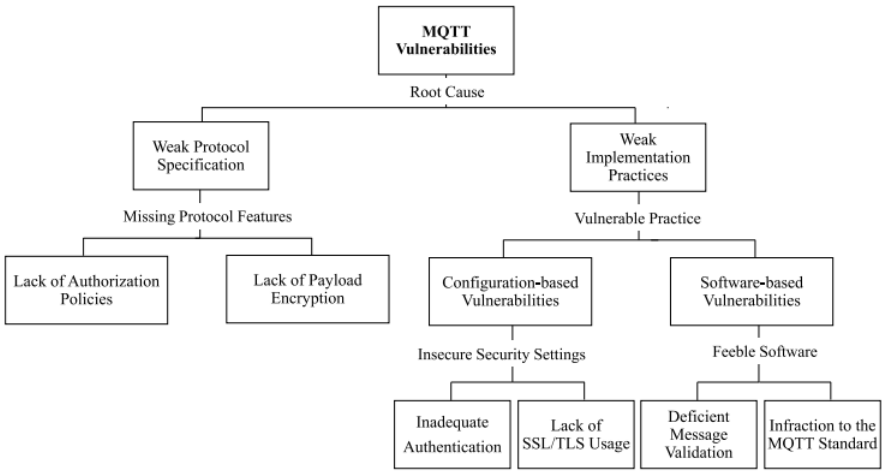

Figure 2.5: Taxonomy of MQTT Vulnerabilities [5]

2.5 A Survey on IoT Application Layer Protocols, Security Challenges, and the Role of Explainable AI in IoT (XAIoT) [2]

The survey provides an overview of IoT architecture with particular emphasis on the application layer and its communication protocols. The application layer enables interaction between IoT devices and users. The survey reviews common protocols, including MQTT, CoAP, MQTT-SN, DDS, XMPP, and HTTP.

Different communication models such as client-server, publish-subscribe, and peer-to-peer are discussed. Although these protocols are designed to be lightweight and suitable for constrained environments, several security weaknesses are identified.

Key security challenges include weak authentication mechanisms, poor key management, spoofing attacks, replay attacks, and denial-of-service attacks. For example, MQTT lacks native secure authentication, CoAP introduces security risks due to UDP-based communication, and DDS faces challenges related to shared key establishment.

The survey also examines the application of machine learning techniques for intrusion detection in IoT systems. Since many machine learning models operate as black boxes, the concept of Explainable AI (XAI) is introduced to improve transparency and trust. A case study using SHAP demonstrates the use of explainable techniques in MQTT-based intrusion detection systems.

The survey concludes by identifying research gaps and future directions, including improved security mechanisms, integration of machine learning with XAI, and enhanced protection for emerging IoT environments.

2.6 Securing and Sustaining IoT Edge-Computing Architectures Through Nanoservice Integration [6]

The study on securing and sustaining IoT edge-computing architectures addresses the need for low-latency, scalable, and secure edge systems. Traditional cloud-centric and container-based architectures introduce high computational overhead, which limits their suitability for resource-constrained IoT environments.

The paper proposes a nano-service-based architecture where each service performs a single task and is dynamically deployed only when required. This approach reduces memory usage, energy consumption, and service execution delay. The architecture follows a three-tier model consisting of IoT devices, edge nodes, and cloud infrastructure.

Security is enforced using a zero-trust model. Mutual authentication, encrypted communication, secure boot mechanisms, least-privilege access control, and service isolation are used to protect nano services. These mechanisms ensure continuous verification of services before execution.

Performance evaluation is carried out using queueing theory and experimental validation on ESP32 and Raspberry Pi platforms. The results show reduced latency and improved energy efficiency compared to centralized architectures.

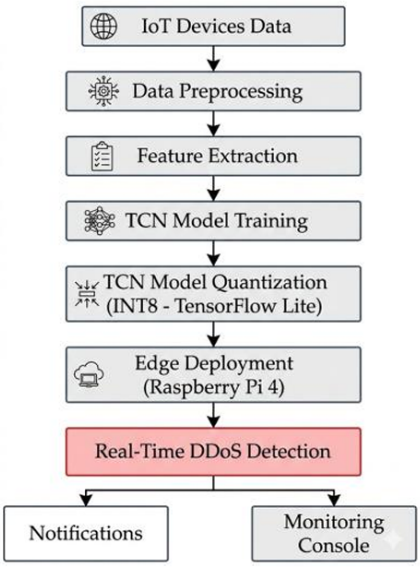

Figure 2.6: Nano-service based IoT edge-computing architecture [6]

2.7 Securing IoT Using Lightweight TCN for Edge Deployment on Raspberry Pi 4 [7]

The referenced work focuses on intrusion detection in IoT environments using a lightweight Temporal Convolutional Network deployed at the edge. Cloud-based intrusion detection systems introduce latency and bandwidth overhead, which limits their effectiveness for real-time IoT protection.

The proposed approach deploys a TCN model on a Raspberry Pi 4 to detect denial-of-service attacks in MQTT and UDP traffic. The model is trained on healthcare IoT datasets and optimized using TensorFlow Lite with full integer quantization. These optimizations reduce memory usage while maintaining detection accuracy.

The deployment pipeline includes traffic preprocessing, feature scaling, TCN inference, and real-time alert generation at the edge device. Latency, power consumption, and detection accuracy are evaluated under realistic conditions.

Experimental results demonstrate that edge-based intrusion detection can achieve high accuracy with low inference latency and reduced energy consumption, making it suitable for real-world IoT deployments.

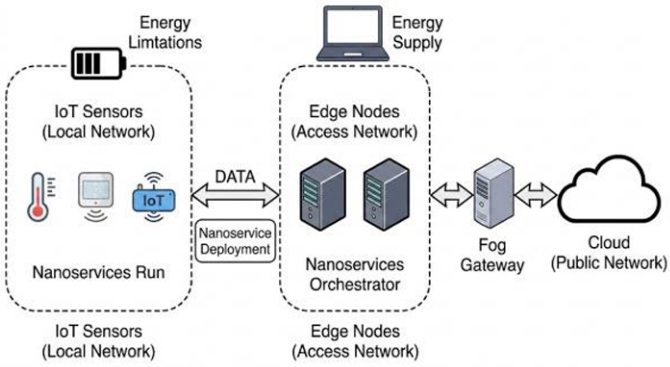

Figure 2.7: Lightweight TCN-based intrusion detection pipeline on Raspberry Pi 4 [8]

2.8 Safeguarding the IoT: Taxonomy, Security Solutions, and Future Research Opportunities [8]

The survey on safeguarding the Internet of Things presents a comprehensive taxonomy of IoT technologies, security threats, and protection mechanisms. The study analyzes IoT security from an architectural perspective and highlights challenges across different layers.

A three-layer IoT architecture is discussed, including the perception layer, network layer, and application layer. For each layer, common vulnerabilities and attacks are identified. Perception layer threats include physical tampering and jamming, network layer threats include man-in-the-middle and routing attacks, and application layer threats include malware and denial-of-service attacks.

The paper classifies attacks based on architectural layers and cross-layer behavior. A PRISMA-based review of existing literature is conducted to identify research trends, limitations, and open challenges. Security solutions such as lightweight cryptography, authentication mechanisms, intrusion detection systems, and key management are discussed.

Emerging research directions include blockchain-based trust management, machine learning-based intrusion detection, edge computing security, and standardization efforts for scalable IoT protection.

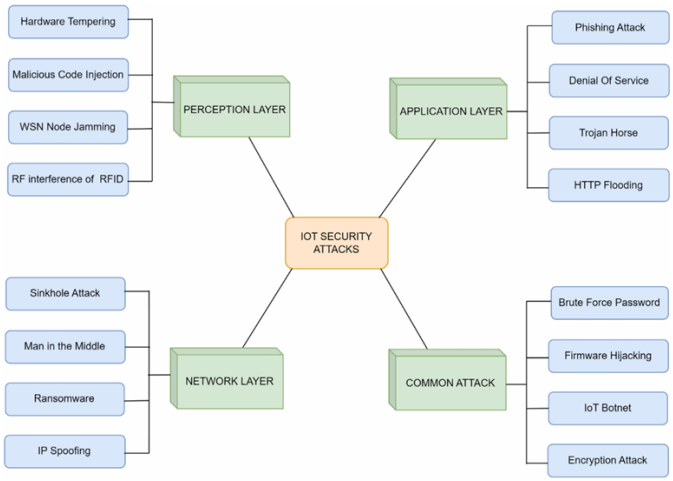

Figure 2.8: IoT security taxonomy across perception, network, and application layers[8]

Security Issues and Challenges in IoT Service and Application Layer

3.1 Introduction

The service and application layer is the top layer of the Internet of Things (IoT) architecture. This layer is responsible for data processing, data storage, user interaction, and communication with cloud services. It includes IoT applications, web dashboards, mobile applications, application programming interfaces (APIs), and cloud platforms [3, 8, 2].

Due to its direct exposure to users and the internet, the service and application layer is more vulnerable to security attacks compared to lower layers [3, 1]. Most IoT application layer protocols are lightweight in nature and are designed mainly for efficiency and low resource usage [5, 2]. As a result, security is often not fully integrated during the design phase, which leads to several security challenges [1, 8].

This chapter discusses the major security issues and challenges in the IoT service and application layer based on existing research studies.

3.2 Overview of Security Challenges

Security issues in the IoT application layer mainly arise due to [3, 1, 8, 2]:

- Lightweight protocol design
- Lack of standard security mechanisms
- Large number of connected devices
- Resource constraints
- Use of cloud and edge services

These challenges affect the confidentiality, integrity, and availability of IoT data and services [3, 8].

3.3 Classification of Security Issues

The security issues in the IoT service and application layer can be classified as follows [1, 8, 2]:

- **IoT Application Layer Security**
  - Protocol Design Issues
  - Data Security Issues
  - Authentication and Authorization Issues
  - Application and API Vulnerabilities
  - Protocol-Specific Attacks
  - Intrusion Detection Challenges
  - Scalability and Resource Constraints
  - Interoperability and Standardization Issues

Each category is explained in the following sections.

3.4 Protocol Design Issues

Most IoT application layer protocols such as MQTT and CoAP are designed to be lightweight and efficient [5, 2]. These protocols do not provide strong security features by default.

Common protocol-level challenges include [5, 1]:

- Lack of built-in authentication mechanisms
- Optional encryption support
- Dependence on external security layers such as TLS or DTLS

Because security is not mandatory in many protocols, misconfiguration can easily expose IoT systems to attacks [5, 2].

3.5 Data Security Issues

IoT applications collect and process a large amount of sensitive data such as personal information, sensor readings, and system logs [3, 8]. Protecting this data is a major challenge at the application layer.

3.5.1 Data Confidentiality

Data confidentiality issues arise when data is transmitted or stored without proper encryption. Attackers can intercept data during communication between devices and cloud services [3, 1].

3.5.2 Data Integrity

Data integrity ensures that information is not altered during transmission or processing. Insecure applications may allow attackers to modify data, which can lead to incorrect system behavior [1, 8].

3.5.3 Data Privacy

IoT systems often collect user data continuously. Poor privacy controls can lead to unauthorized data access, data misuse, and violation of user privacy [3, 8].

3.6 Authentication and Authorization Issues

Authentication and authorization are critical for controlling access to IoT services and applications. However, many IoT systems use weak or improper access control mechanisms [3, 1].

Common challenges include:

- Use of default or weak credentials
- Lack of role-based access control
- Poor session and token management

These weaknesses allow attackers to gain unauthorized access to IoT services and devices [1, 8].

3.7 Application and API Vulnerabilities

IoT service layers rely heavily on APIs and web applications to communicate with devices and users [3, 1]. Insecure APIs are one of the most common attack points.

Typical issues include [1, 8]:

- APIs exposed without authentication
- Hardcoded API keys and tokens
- Lack of input validation
- Absence of rate limiting

Exploiting these vulnerabilities allows attackers to steal data or control IoT devices [1].

3.8 Protocol-Specific Attacks

Certain attacks are specific to IoT application layer protocols [5, 2].

In MQTT-based systems, the central broker plays a critical role. If the broker is compromised, the entire IoT system can be affected [5].

Common protocol-specific attacks include:

- Unauthorized topic subscription
- Message replay attacks
- Flooding and denial-of-service attacks
- Spoofing attacks

These attacks mainly target the communication model used by the protocol [5, 1].

3.9 Intrusion Detection Challenges

Traditional intrusion detection systems are not well suited for IoT environments due to limited resources and large traffic volume [4, 2].

Key challenges include:

- High false positive rates
- Encrypted traffic analysis difficulty
- Limited processing power at edge devices

Although machine learning-based intrusion detection systems improve detection accuracy, they often lack transparency and require high computational resources [4, 7].

3.10 Scalability and Resource Constraints

IoT systems consist of a large number of devices that continuously generate data. Implementing security mechanisms at scale is challenging [8, 6].

Major issues include:

- Managing identities for thousands of devices
- Increased attack surface
- Performance degradation due to security overhead

Resource limitations at edge and IoT devices further restrict the use of complex security solutions [6, 7].

3.11 Interoperability and Standardization Issues

IoT ecosystems include devices, protocols, and platforms from different vendors. Lack of standardization creates security gaps [8, 2].

Challenges include:

- Inconsistent security implementations
- Vendor-specific security solutions
- Difficulty in applying uniform security policies

This heterogeneity increases system complexity and vulnerability [8].

3.12 Attack Flow in IoT Application Layer

A typical attack flow in the IoT application layer can be illustrated as follows:

This shows how a single weakness at the application layer can compromise the entire IoT system [1, 8].

```
Attacker
   |
   v
Exploits API or Protocol Weakness
   |
   v
Gains Unauthorized Access
   |
   v
Steals or Modifies Data
   |
   v
Controls IoT Services or Devices
   |
   v
Service Disruption or Privacy Violation
```

Figure 3.1: Typical attack flow in the IoT application layer[8]

3.13 Summary

The IoT service and application layer faces multiple security challenges due to lightweight protocol design, weak access control, insecure APIs, and scalability issues [3, 1, 8, 2]. Addressing these challenges requires secure protocol configuration, strong authentication mechanisms, proper data protection, and continuous monitoring of IoT services.

Proposed Solutions

4.1 Introduction

The IoT service and application layer is exposed to many security threats because it directly handles data processing, user interaction, and communication with cloud services. Common problems include weak authentication, insecure data transmission, poor protocol configuration, and lack of monitoring [3].

Since these security issues occur at different points in the system, a single solution is not sufficient. Therefore, security must be applied in a structured manner using multiple methods [8]. This chapter presents categorized solutions with simple explanations and examples for better understanding.

4.2 Authentication and Access Control Solutions

Authentication and access control ensure that only trusted devices, users, and applications can access IoT services. These mechanisms help prevent unauthorized data access, misuse of APIs, and malicious device connections [2].

Table 4.1 summarizes the most common authentication and access control methods used in IoT systems.

Method	**What it does**	**Where used**	**Tools**
Certificates (TLS/DTLS)	Verifies device identity	MQTT, CoAP, HTTP	AWS IoT, Mosquitto
Pre-Shared Keys (PSK)	Lightweight authentication	Edge devices	EMQX, wolfSSL
Tokens (JWT)	Controls API access	REST services	OAuth 2.0, Keycloak
Role-Based Access	Limits user privileges	Dashboards	IAM systems
Hardware Identity	Prevents device cloning	Critical IoT nodes	TPM, Secure Elements

Table 4.1: Authentication and Access Control Methods

Certificate-based methods are widely used in cloud IoT platforms, while PSK-based methods are suitable for resource-constrained devices. Token-based access control is commonly used for securing APIs and web services [8].

4.3 Data Protection and Secure Communication

Data protection focuses on keeping IoT data confidential and unchanged during transmission and storage. Secure communication mechanisms prevent attackers from reading or modifying data [3].

Table 4.2 presents common data protection techniques used at the application and service layers.

Technique	Purpose	Applied at	Tools
TLS / DTLS	Encrypts data in transit	Network links	OpenSSL, mbedTLS
End-to-End Encryption	Protects application data	App layer	libsodium
Message Authentication	Ensures data integrity	MQTT messages	HMAC, CMAC
Encrypted Storage	Protects stored data	Cloud / Edge	SQLCipher
Key Management	Manages cryptographic keys	Cloud services	AWS KMS

Table 4.2: Data Protection and Secure Communication Techniques

TLS and DTLS are the most commonly used methods for securing IoT communication. Message authentication codes are often used when encryption is not possible due to resource limitations [5].

4.4 Protocol-Level Security Solutions

IoT application layer protocols are lightweight by design and often require additional security configuration [5]. Protocol-level security helps protect communication between devices and services.

Table 4.3 shows security solutions for common IoT protocols.

Protocol	Security method	Threat addressed	Tools
MQTT	TLS + Access Control	Unauthorized publish/subscribe	EMQX, Mosquitto
CoAP	DTLS / OSCORE	Spoofing, replay	Californium
HTTP/2	TLS encryption	API interception	NGINX, Envoy
AMQP	SASL + TLS	Broker attacks	RabbitMQ

Table 4.3: Protocol-Level Security Solutions

These security mechanisms help protect communication channels and reduce protocol-specific attacks such as spoofing and message manipulation [1].

4.5 Application and API Security Solutions

IoT applications expose APIs and user interfaces that can be targeted by attackers. Application security focuses on protecting these components from misuse and abuse [8].

Table 4.4 summarizes common application and API security solutions.

Solution	What it does	Threat prevented	Tools
API Authentication	Verifies API users	Broken authentication	OAuth, JWT
Rate Limiting	Limits request rate	DoS attacks	NGINX, Kong
Input Validation	Checks request data	Injection attacks	JSON Schema
Web Firewall (WAF)	Filters malicious traffic	XSS, SQLi	ModSecurity
Logging	Tracks system activity	Hidden attacks	SIEM tools

Table 4.4: Application and API Security Solutions

These controls reduce common web-based attacks and help administrators detect abnormal behavior [1, 8].

4.6 Intrusion Detection and Monitoring

Intrusion detection systems monitor network traffic and system activity to identify suspicious behavior. Monitoring helps detect attacks that bypass preventive security controls [7].

Table 4.5 presents commonly used monitoring techniques.

Type	Detection method	Location	Tools
Network IDS	Traffic analysis	Gateways	Suricata, Zeek
Host IDS	System behavior	Edge devices	Wazuh, OSSEC
ML-Based IDS	Anomaly detection	Edge / Cloud	EBIDS, TCN
Log Analysis	Event correlation	Central server	Elastic Stack

Table 4.5: Intrusion Detection and Monitoring Techniques

Combining multiple monitoring methods improves attack detection accuracy [4].

4.7 Edge-Based Security Solutions

Edge devices often have limited memory and processing power. Therefore, lightweight security solutions are required to balance protection and performance [6, 7].

Table 4.6 lists suitable edge-based security methods.

Method	Purpose	Device type	Tools
Lightweight Crypto	Low-cost encryption	Sensors	Ascon, AES
TinyML IDS	Local attack detection	Edge nodes	TFLite Micro
Secure Boot	Prevents firmware tampering	IoT devices	MCUboot
Hardware Identity	Ensures device trust	Critical nodes	Secure Elements

Table 4.6: Edge-Based Security Methods

These solutions allow security to be applied close to the data source without high overhead [6].

4.8 Standardization and Secure Configuration

Many IoT security problems occur due to misconfiguration and lack of standards [2]. Following best practices and security standards reduces these risks.

Table 4.7 highlights key standardization and configuration practices.

Practice	Purpose	Example
Secure Defaults	Avoid weak settings	Disable plaintext MQTT
Regular Updates	Fix known issues	OTA updates
Security Standards	Ensure compliance	ETSI EN 303 645
Config Automation	Reduce human error	Ansible scripts

Table 4.7: Standardization and Configuration Practices

Applying these practices helps maintain consistent security across IoT deployments [8].

Conclusion and Future works

This work examined security challenges and solutions at the IoT application and service layers. The analysis shows that these layers face multiple security threats due to lightweight protocol design, large-scale deployments, and complex service architectures. As a result, a single security mechanism is not sufficient, and a layered security approach is required [8].

The study highlights that application layer protocols such as MQTT and CoAP do not provide strong security by default. Secure configuration using TLS, DTLS, or OSCORE is necessary to prevent unauthorized access and message manipulation. In addition, the limited resources of edge devices require lightweight encryption techniques and efficient intrusion detection methods.

At the service layer, the use of cloud platforms, APIs, and microservices increases system complexity. This makes strong access control, secure API management, and continuous monitoring essential. Traditional intrusion detection systems are often not effective for application-layer attacks, and machine learning-based detection methods can improve attack detection when properly monitored and explained.

Another important observation is that many security incidents are caused by poor configuration and lack of standard practices. Following security standards and using automated configuration tools can significantly reduce these risks.

Overall, the proposed layered security approach improves protection at the IoT application and service layers while maintaining system performance and scalability. The solutions discussed in this work provide a practical foundation for securing real-world IoT systems.

5.1 Future Research Directions

Although significant progress has been made in IoT security, several challenges remain and require further research.

5.1.1 Post-Quantum Cryptography

Future IoT systems must be prepared for cryptographic threats posed by quantum computing. Research is needed to adapt post-quantum cryptographic algorithms for IoT application protocols such as MQTT and CoAP. Lightweight implementations suitable for resource-constrained devices are especially important.

5.1.2 Explainable Machine Learning for IoT Security

Machine learning-based intrusion detection systems can improve security, but their decisions are often difficult to understand. Future research should focus on explainable detection techniques that help administrators understand why an attack was detected. This will improve trust and usability in real deployments.

5.1.3 Zero Trust Security Models

Zero trust security models require continuous verification of devices and services. Further work is needed to integrate zero trust principles across heterogeneous IoT environments that include edge devices, gateways, and cloud services.

5.1.4 Automated Threat Detection and Response

Automating threat detection and response can reduce reaction time during attacks. Research into safe and controlled automation techniques can help prevent damage while avoiding unintended system disruptions.

5.1.5 Supply Chain Security

IoT security also depends on trusted hardware and software supply chains. Future studies should focus on secure firmware updates, hardware-based trust mechanisms, and verification of third-party components.

5.1.6 Protocol-Aware Security Mechanisms

Application layer protocols carry structured data that can be analyzed for abnormal behavior. Research into protocol-aware security mechanisms can improve detection of advanced and unknown attacks.

5.1.7 Regulatory and Standardization Challenges

As IoT deployments grow globally, consistent security regulations and standards are required. Future research should consider how technical solutions can align with regulatory requirements and industry best practices.

5.1.8 Performance Goals for Future IoT Systems

Metric	Current State	Future Target
Edge Detection Latency	Few milliseconds	Sub-millisecond
Cryptographic Overhead	Moderate	Low
False Alert Rate	Below 1%	Below 0.1%
Configuration Compliance	High	Near complete
Quantum Resistance	Limited	Fully supported

Table 5.1: Expected Performance Improvements in Future IoT Systems

The future of IoT security depends on combining improved cryptographic methods, intelligent detection systems, strong access control, and standardized security practices. Addressing these areas will help ensure secure and reliable IoT systems in the coming years.

Bibliography

[1] S. K. Bhoi, U. Ghugar, S. Dash, R. Nayak, and D. K. Bagal, "Exploring the security landscape: A comprehensive analysis of vulnerabilities, challenges, and findings in internet of things application layer protocols," *Migration Letters*, 2024.

[2] V. E. Quincozes, S. E. Quincozes, J. F. Kazienko, S. Gama, O. Cheikhrouhou, and A. Koubaa, "A survey on iot application layer protocols, security challenges, and the role of explainable ai in iot," *International Journal of Information Security*, 2024.

[3] M. Abbasi, J. Prieto, M. Plaza-Hernández, and J. M. Corchado, "Security in the internet of things application layer: Requirements, threats, and solutions," *IEEE Access*, 2021.

[4] S. Sattarpour, A. Barati, and H. Barati, "Ebids: Efficient bert-based intrusion detection system in the network and application layers of iot," *Journal of Network and Computer Applications*, 2024.

[5] "Securing the iot application layer from an mqtt protocol perspective: Challenges and research prospects," *IEEE Communications Surveys & Tutorials*, 2022.

[6] "Securing and sustaining iot edge-computing architectures through nanoservice integration," *IEEE Internet of Things Journal*, 2021.

[7] M. Akhi, C. Eising, and L. L. Dhirani, "Securing iot using lightweight tcn for edge deployment on raspberry pi 4," *IEEE Open Journal of the Communications Society*, vol. PP, no. 99, pp. 1–1, 2025. DOI: 10.1109/OJCOMS.2025.3649498

[8] A. Patel et al., "Safeguarding the iot: Taxonomy, security solutions, and future research opportunities," *Security and Privacy*, 2024.